

Usage Guide

A step-by-step walkthrough, by role

v1.1.0

June 2026

Roles in the tags below indicate who can perform an action. **Viewers** see everything but editing/run actions are hidden or disabled. In **Local mode** (no backend) everything is enabled for a single user.

1. Sign In

1. Open the app (`localhost:5173` in dev, `localhost:8080` via Docker).
2. Enter email + password, or click a **demo account** (password `Demo!1234`).
3. You land on the **Dashboard**. Your session is private (httpOnly cookie); your role shows top-right. Sign out from the account menu.

2. Dashboard — Read Your Posture

- **Top row:** protected layers, open risks, critical gaps, active incidents.
- **Vendor Protection & Model Coverage:** files scanned, malicious blocked, injections blocked, models covered, local protected, unguarded, high-risk.
- **AI Security Score** ring with the bonuses/penalties behind it; **Layer Posture**, recent incidents, compliance status.

Use the **project selector** (top-left) to switch projects; set a default in Settings.

3. LLM Stack Map — See The Architecture

1. Open **LLM Stack Map**.
2. Pan/zoom the defense-in-depth flow; nodes are colored by status.
3. **Click any node** to open the inspector. **EDITORS** change status, owner, evidence link, notes, or delete.

4. Layer Assessment — Mark Maturity **APPSEC / OWNER**

Set each control **Not implemented** → **Planned** → **Implemented** → **Verified**. Per-layer coverage % updates instantly and the score recalculates.

5. Risk Register — Track Threats **SOC / APPSEC / OWNER**

1. Filter by severity; expand a risk to see mitigating controls + OWASP mapping.
2. Change a risk's **status** (Open → Mitigating → Mitigated / Accepted).

6. Control Library & Architecture Builder

- **Control Library** — browse/filter all controls; **APPSEC / OWNER** add a control or change status inline.
- **Architecture Builder** — drag controls from the palette onto the canvas and arrange them; click a node to edit.

7. File Security Gateway — Scan A File | SOC / APPSEC / OWNER

1. Choose an **ingestion source** and **scan engine** (Check Point Threat Emulation / TE File Scan).
2. **Drop a file** (or browse). It's hashed locally and scanned.
3. Read the **verdict**; malicious & suspicious files are **blocked from retrieval**. Open the evidence viewer or **Retry**.

Demo tip: filenames containing `malware`, `.exe`, `macro`, or `invoice-` return bad verdicts so blocking is demonstrable.

8. Lakera Guard — Inspect A Prompt | SOC / APPSEC / OWNER

1. Pick **Input** or **Output** stage; paste a prompt (or use a sample).
2. Click **Send to Lakera Guard** → risk score, decision (allow / block / redact / escalate), and violation categories; added to the **Inspection Log**. Tune thresholds in the Policy panel.

9. Model Coverage — Register, Test & Evaluate

1. | **APPSEC / OWNER** **Register model** — provider, deployment (hosted/local/custom), endpoint, environment, sensitivity, owner, use case. Local models add network-isolation / internet-access / integrity controls.
2. Toggle guardrails (input/output/tool/logging); per-model **risk level** updates.
3. **Test** — checks the endpoint is reachable (latency).
4. **Evaluate** — runs an adversarial probe suite (prompt injection, system-prompt leakage, jailbreak, harmful content, PII) and reports a **resilience score** with each probe's verdict + the model's actual response. Unreachable endpoints produce a **simulated** result.

Evaluate a real local LLM (Ollama):

```
ollama pull llama3.2:1b
# Register a local model with endpoint http://localhost:11434/api/generate
# and model name "llama3.2:1b", then click Evaluate.
```

10. Integrations

See each vendor connector's **status** (mock / connected), auth method, base URL, and protected layers. | **OWNER**
enable/disable a connector. The **API Key Configuration** panel lists the env variables to switch to live mode.

11. Compliance — Frameworks & Reports

1. Pick a framework — **OWASP LLM Top 10**, **NIST AI RMF**, **EU AI Act**, **ISO/IEC 42001**, **MITRE ATLAS**. Each shows coverage % and covered/partial/gap counts.
2. Expand a requirement to see the **controls mapped** to it and their status.
3. **Export report** downloads a per-framework Markdown compliance report.

12. Report Generator

The full assessment — executive summary, architecture overview, layer findings, control status, gaps, remediation plan. Export as **Markdown** or **PDF** (Print).

13. Settings

- **Profile & Session** — your name, email, role, and session info.
- **Preferences** — language, default project, notifications. These save to **your account** and follow you across devices/sessions.
- **User Management** | **OWNER** — **Add user** (email, name, role, temporary password); change role inline, reset password, or delete. You can't delete yourself or the last Owner.

★ Quick Role Reference

ACTION	OWNER	APPSEC	SOC	VIEWER
View everything	✓	✓	✓	✓
Edit controls / models	✓	✓	—	—
Edit risks / incidents	✓	✓	✓	—
Run scans / inspections / model evals	✓	✓	✓	—
Toggle integrations	✓	—	—	—
Manage users	✓	—	—	—